

# TP Cybersécurité des Systèmes Industriels — Rapport

Analyse, attaque et détection sur une plateforme OT/ICS virtualisée

John — École 2600 (A2/C7 IT-OT)

2026-06-12

## 1. Résumé exécutif

La plateforme étudiée simule un système de gouverne navale (deux gouvernails *bâbord* et *tribord*) piloté par un automate (PLC) et supervisé par un SCADA au travers d'un Contrôleur-Coordinateur (CC). En fonctionnement nominal, les gouvernails suivent fidèlement l'ordre de barre, qui balaie continûment la plage **0-80**.

L'analyse a montré que le CC expose, sur le réseau host-only, **deux surfaces d'attaque non authentifiées** :

1. une **API web** (/attack, /restore) permettant de manipuler directement les valeurs « métier » de l'automate ;
2. un **serveur Modbus/TCP** (port 502) acceptant des écritures de n'importe quelle source.

La VM *Attacker* exploite la première : un simple GET /attack?plc=gouv&choice=1 &offset=10 répété **fige le gouvernail** (perte de gouverne) tandis que l'ordre de barre continue d'évoluer — une atteinte directe à l'**intégrité** et à la **disponibilité** du procédé. Nous avons reproduit l'attaque, démontré une seconde variante d'**injection de fausses données** (divergence et débordement entier), puis défini une **stratégie de détection orientée métier** : corrélation ordre/gouvernail, détection de valeur figée, et règles réseau sur les écritures Modbus et les appels HTTP /attack.

## 2. Architecture de la plateforme

### 2.1 Inventaire des machines

| VM       | Rôle                             | Réseau(x)                   | Adresse(s)                   |
|----------|----------------------------------|-----------------------------|------------------------------|
| NTP      | Référence de temps               | host-only                   | 192.168.15.3                 |
| PLC      | Contrôle de la partie opérative  | interne x2                  | 192.168.200.3 / .4           |
| CC       | Interface commande ↔ supervision | host-only <b>et</b> interne | 192.168.15.1 / 192.168.200.1 |
| SCADA    | Visualisation du procédé         | host-only                   | 192.168.15.2                 |
| Attacker | Poste attaquant                  | host-only                   | 192.168.15.4                 |

Deux réseaux VirtualBox cohabitent :

- **host-only vboxnet0 — 192.168.15.0/24** : NTP, SCADA, Attacker, et la patte « supervision » du CC.
- **interne intnet — 192.168.200.0/24** : le PLC, et la patte « commande » du CC.

Le **CC est l'unique pont** entre les deux réseaux. Le PLC n'est donc **jamais joignable directement** depuis le segment où se trouve l'attaquant : toute action sur l'automate transite obligatoirement par le CC. C'est un point central de l'analyse.

### 2.2 Flux de données et carte des registres

Le procédé est porté par des registres Modbus *holding* de l'automate (192.168.200.3). Le CC agit comme **client Modbus** vis-à-vis du PLC, et comme **serveur Modbus + serveur web** vis-à-vis de la supervision.

```

SCADA (.2) --FC6 write reg40 (ordre)--> CC (.1:502)
                                         |
CC (200.1) --FC6 write reg40-----> PLC (200.3)    [ordre de barre]
CC (200.1) --FC3 read reg108/109----> PLC (200.3)    [gouvernail L/R]
CC (200.1) --FC3 read reg54/56-----> PLC (200.3)    [gouvernail physique L/R]
                                         |
CC web (.1:80) GET / -----+ => JSON metier (teleservice)

```

Carte des registres reconstituée par capture (cf. §4) :

| Champ JSON            | Registre PLC             | Sens     | Signification                        |
|-----------------------|--------------------------|----------|--------------------------------------|
| order_rub             | holding <b>40</b>        | écriture | Ordre de barre (consigne)            |
| l_rub / r_rub         | holding <b>108 / 109</b> | lecture  | Position gouvernail bâbord / tribord |
| phy_l_rub / phy_r_rub | holding <b>54 / 56</b>   | lecture  | Position physique réelle             |
| fuel                  | holding <b>7</b> (.4)    | lecture  | Niveau de carburant                  |

L'état métier est consultable en clair via GET <http://192.168.15.1/> :

```
{
  "l_rub":46,"r_rub":46,"fuel":100,"refuel":0,
  "order_rub":69,"phy_l_rub":46,"energy_speed":0,"phy_r_rub":46}

```

### 3. Comportement « métier » nominal

En l'absence d'attaque (ordre de démarrage NTP → PLC → CC → SCADA), le SCADA émet en continu un **ordre de barre** qui décrit une **rampe triangulaire** balayant la plage 0-80. Le gouvernail **suit fidèlement** cet ordre : à tout instant,  $l\_rub \approx r\_rub \approx phy\_l\_rub \approx phy\_r\_rub \approx order\_rub$  (écart  $\leq 1$ ).

Extrait de relevé nominal (order mène, le gouvernail suit) :

| ts       | $l\_rub$ | $r\_rub$ | order | $phy\_l$ | $phy\_r$ |
|----------|----------|----------|-------|----------|----------|
| 17:10:38 | 26       | 26       | 27    | 26       | 26       |
| 17:10:40 | 28       | 28       | 29    | 28       | 28       |
| 17:10:42 | 31       | 31       | 31    | 31       | 31       |
| 17:10:44 | 32       | 32       | 33    | 32       | 32       |

**Invariant métier fondamental** : *la position du gouvernail suit l'ordre de barre*. C'est cet invariant que l'attaque va briser, et c'est lui qui fonde notre stratégie de détection.

Côté réseau, le trafic nominal est régulier et **prévisible** :

- SCADA (.2) écrit l'ordre (FC6, registre 40) sur le CC,  $\sim 1$  fois/seconde ; **seule** la .2 réalise cette écriture (85 requêtes .2 → reg40 sur la fenêtre de référence, 0 provenant d'une autre source) ;
- le CC interroge le PLC en lecture (FC3, reg 108/109/54/56) et lui réécrit l'ordre (FC6, reg 40).

### 4. Méthodologie d'investigation

L'objectif était d'observer **toutes** les communications, y compris le dialogue PLC ↔ CC situé sur le réseau interne, **invisible depuis l'hôte**. La capture hôte classique (tshark -i vboxnet0) ne voit que le segment host-only.

**Solution retenue — traçage au niveau de l'hyperviseur**. Le CC possédant une patte sur *chaque* réseau, nous avons activé la capture VirtualBox sur ses deux interfaces, ce qui restitue à la fois le segment supervision et le segment commande, sans privilège root sur l'hôte :

```
VBoxManage controlvm CC nictrace1 on # patte interne (PLC)
VBoxManage controlvm CC nictracefile1 cc_intnet.pcap
VBoxManage controlvm CC nictrace2 on # patte host-only (SCADA/Attacker)
VBoxManage controlvm CC nictracefile2 cc_hostonly.pcap
```

Les .pcap ont ensuite été dépouillés avec tshark (dissecteur Modbus) et corrélés au téléservice JSON échantillonné en parallèle. Toute la démarche est rejouable : remise à l'état initial par la procédure documentée (extinction puis redémarrage NTP → PLC → CC → SCADA).

**Note méthodologique**. Une première tentative d'injection Modbus brutale (écritures massives sur le registre 40) a **figé l'automate de manière non réversible** par /restore, imposant un redémarrage complet. Sur un système réel où *la disponibilité prime*, ce constat est en soi un résultat : une sonde de test mal calibrée peut provoquer l'incident qu'elle cherche à étudier. Les essais suivants ont été menés de façon incrémentale et restaurés entre chaque variante.

## 5. Analyse de l'attaque

### 5.1 Identification

Au lancement de la VM *Attacker* (192.168.15.4), le comportement métier change **immédiatement** : le gouvernail se **fige** (ici à 46, puis 50 selon l'essai) alors que l'ordre de barre, lui, continue de balayer la plage.

| ts       | l_rub | r_rub | order | phy_l | phy_r |                                    |
|----------|-------|-------|-------|-------|-------|------------------------------------|
| 17:12:18 | 46    | 46    | 44    | 46    | 46    | ← gouvernail figé, ordre qui varie |
| 17:12:30 | 46    | 46    | 36    | 46    | 46    |                                    |
| 17:12:45 | 46    | 46    | 21    | 46    | 46    |                                    |

- **Modification métier** : rupture de l'invariant « le gouvernail suit l'ordre ». La barre ne répond plus → **perte de gouverne**.
- **Machine ciblée** : le **PLC** (la gouverne / plc=gouv), atteint **au travers du CC** — seul pont vers le réseau de commande.

### 5.2 Vecteur d'attaque

La capture du segment host-only révèle l'unique action offensive de la VM attaquante :

192.168.15.4 → 192.168.15.1 GET /attack?plc=gouv&choice=1&offset=10

L'attaquant n'utilise **ni exploit, ni authentification** : il appelle une **API web exposée par le CC**. L'inspection de la spécification OpenAPI (/openapi.json, exposée par FastAPI/uvicorn) confirme trois routes :

| Route    | Paramètres                      | Effet                                  |
|----------|---------------------------------|----------------------------------------|
| /        | —                               | Téléservice JSON (lecture du procédé)  |
| /attack  | plc, choice (int), offset (int) | Manipulation d'une variable du procédé |
| /restore | plc                             | Annulation de la manipulation          |

### 5.3 Scénarios d'attaque mis en œuvre

Nous avons cartographié l'API par essais successifs (restauration entre chaque) :

- **Scénario A — Gel du gouvernail (déni de gouverne)**. choice=1 appelé **en boucle** fige la position du gouvernail à sa valeur courante (30, 46, 50... selon l'instant) tandis que l'ordre continue d'évoluer. C'est l'attaque effectivement portée par la VM *Attacker*. Impact : **perte de disponibilité** de la fonction de gouverne — critique sur un navire.
- **Scénario B — Injection de fausses données (atteinte à l'intégrité)**. choice=2 introduit un **biais** entre l'ordre et la valeur remontée (écart mesuré jusqu'à 11). Avec offset=40, la valeur subit un **débordement entier non signé** et remonte à **65510** ( $\approx -26$  sur 16 bits). La supervision affiche alors une position aberrante : un opérateur peut être trompé, ou un automatisme aval déclenché à tort.
- **Scénario C — Injection de commande Modbus**. Indépendamment de l'API web, le serveur Modbus du CC (.1:502) accepte des **écritures non authentifiées**. Une écriture FC6 sur le **registre 40** depuis une source arbitraire force la valeur order\_rub :

reg40 ← 65 ⇒ order\_rub == 65 (consigne usurpée)

Le protocole Modbus n'offrant **ni authentification ni intégrité**, n'importe quelle machine du segment peut usurper la consigne de barre.

## 6. Stratégie de détection

Conformément à l'esprit OT (« la donnée a une signification physique, la disponibilité prime »), la détection combine une couche **métier** (la plus robuste) et une couche **réseau**.

### 6.1 Détection métier (process-aware)

**D1 — Rupture de corrélation ordre/gouvernail.** C'est le détecteur clé. On surveille l'écart  $|\text{order\_rub} - \text{phy\_l\_rub}|$ . En nominal il reste  $\leq 1$  ; sous attaque (gel ou biais) il diverge durablement.

*# pseudo-règle, évaluée à chaque cycle*

```
if abs(order_rub - phy_l_rub) > SEUIL and persiste(> 3 s):  
    alerte("rupture corrélation barre/gouvernail – possible manipulation")
```

**D2 — Valeur de procédé figée.** Une variance quasi nulle du gouvernail alors que l'ordre varie trahit un actionneur bloqué :

```
if variance(phy_l_rub, fenetre=5s)  $\approx$  0 and variance(order_rub, 5s) > 0:  
    alerte("gouvernail figé – déni de gouverne")
```

**D3 — Valeurs hors domaine physique.** Le gouvernail évolue dans 0-80. Toute valeur hors plage (ex. 65510) est physiquement impossible : contrôle de domaine systématique sur chaque grandeur.

### 6.2 Détection réseau (NIDS)

**D4 — Écritures Modbus illégitimes.** En nominal, **seule la SCADA (.2)** écrit le registre 40. Toute écriture FC6/FC16 provenant d'une autre source, ou visant un registre inattendu, est une anomalie. Règle Suricata indicative :

```
alert modbus any any -> 192.168.15.1 502 (msg:"OT write reg40 source non-SCADA";  
    modbus.function:6; flow:to_server; not src_ip:192.168.15.2; sid:1000041;)
```

**D5 — Appels à l'API d'attaque.** Tout GET /attack (ou /restore) sur le CC est, en exploitation normale, anormal. Surveillance applicative côté CC + règle HTTP NIDS :

```
alert http any any -> 192.168.15.1 80 (msg:"CC /attack endpoint hit";  
    http.uri; content:"/attack"; sid:1000080;)
```

**D6 — Apparition d'un hôte non inventorié.** Le démarrage de .4 (l'attaquant) est détectable par supervision ARP/inventaire : toute IP/MAC hors liste blanche sur vboxnet0 lève une alerte.

### 6.3 Synthèse couverture

| Détecteur       | Scénario A (gel) | Scénario B (biais) | Scénario C (Modbus) |
|-----------------|------------------|--------------------|---------------------|
| D1 corrélation  | ✓                | ✓                  | ✓                   |
| D2 valeur figée | ✓                | —                  | —                   |
| D3 hors-domaine | —                | ✓                  | partiel             |
| D4 write Modbus | —                | —                  | ✓                   |
| D5 API /attack  | ✓                | ✓                  | —                   |
| D6 inventaire   | ✓                | ✓                  | ✓                   |

La redondance métier + réseau garantit qu'aucun scénario n'échappe à au moins deux détecteurs indépendants.

## 7. Recommandations

1. **Supprimer la surface d'attaque applicative.** Les routes /attack et /restore n'ont aucune raison d'exister en production : à retirer. Plus généralement, le téléservice doit être en **lecture seule** et authentifié.
2. **Segmenter et filtrer.** Le CC étant l'unique pont, il doit appliquer un **filtrage strict** : n'autoriser le port 502 *que* depuis la SCADA, et le port 80 *que* depuis les postes de supervision légitimes. Idéalement, un pare-feu OT (ou une diode de données pour le téléservice) entre supervision et commande.
3. **Sécuriser le Modbus.** Modbus/TCP étant non authentifié, déployer **Modbus/TLS** ou encapsuler dans un tunnel authentifié ; à défaut, verrouiller par ACL et n'autoriser l'écriture que depuis la source légitime, avec contrôle de plage des consignes (la barre  $\in [0, 80]$ ).
4. **Détection orientée métier en production.** Industrialiser D1-D3 dans le CC ou un historian : la corrélation ordre/gouvernail est un capteur d'intégrité peu coûteux et très discriminant.
5. **Sûreté de fonctionnement.** L'automate doit **rejeter une consigne incohérente** (saut brutal, hors plage) plutôt que se figer : un mode dégradé maîtrisé (maintien de cap + alarme) vaut mieux qu'un blocage silencieux de la gouverne.
6. **Inventaire et NAC.** Liste blanche MAC/IP sur les segments OT ; toute machine non inventoriée (l'attaquant) doit être bloquée et alarmée.

## 8. Conclusion

La plateforme illustre un risque classique des SI industriels : des **fonctions de commande exposées sans authentification** depuis un segment accessible. Sans aucun exploit, un simple appel HTTP suffit à **priver le navire de gouverne**. La défense la plus robuste n'est pas seulement réseau : elle s'appuie sur la **connaissance du procédé** — l'invariant « le gouvernail suit l'ordre » détecte les trois scénarios étudiés, y compris ceux qui n'émettent aucun paquet malveillant identifiable au niveau protocolaire.

---

*Annexes (captures .pcap, scripts d'analyse et d'attaque, relevés) fournies dans le dossier work/.*